PHP2Shell Core Vulnerabilities

CVE-2026-109618, CVE-2026-109619, and RCE Mechanics

1. Anatomy of the PHP2Shell Vulnerabilities (CVE-2026-109618 & CVE-2026-109619)

In October 2026, the PHP project released emergency security patches for two critical, pre-authentication remote code execution (RCE) vulnerabilities collectively dubbed "PHP2Shell". Affecting virtually all PHP releases from versions 5.4 through 8.5.11, these flaws exist within the core memory and request lifecycle handling of the PHP runtime engine itself. Because these bugs live beneath the application layer, standard web application firewalls (WAFs) and userland sanitization scripts are completely bypassed. An unauthenticated attacker can manipulate raw HTTP requests to trigger engine-level memory corruption before any user code executes.

2. Exploiting Control Flow Desync and Persistent Workers

The attack chain combines two distinct memory management failures. Under CVE-2026-109618, crafted multipart file uploads or deeply nested payloads trigger a premature out-of-memory (OOM) error. During the resulting `longjmp()` unwind, partially initialized request structures are treated as valid objects by cleanup routines, enabling control flow hijacking. Simultaneously, CVE-2026-109619 exploits the session upload-progress feature. When fatal errors interrupt multipart handling, session cleanup is skipped while the request memory is freed. Persistent PHP-FPM workers retain dangling pointers to this freed memory, allowing subsequent requests handled by the same process to execute attacker-controlled memory.

3. AI-Accelerated Exploit Synthesis

A critical anomaly observed during the disclosure window was the rapid compression of the vulnerability-to-exploitation timeline. Threat intelligence networks logged active exploitation attempts prior to widespread patch deployment. Rather than taking weeks of manual reverse-engineering, threat actors utilized autonomous LLM code parsing and AST control-flow graphing to diff patches, locate structural memory offsets, and synthesize weaponized multi-part HTTP payloads within hours.

4. The Danger of Legacy Core Engines

PHP2Shell serves as a stark reminder that high-level abstractions built on legacy C runtimes inherit raw memory management risks. When performance optimization reuses worker processes across stateless HTTP boundaries, a single memory leak converts a temporary error into persistent code execution.